BSIDESTLV 2026 · BUG BOUNTY VILLAGE

Redirected.

Open redirect in the real world - how to send a phishing email.

ABOUT ME



Avishai Gonen

A cyber security researcher. In my free time I do CTFs, bug bounty, and independent research. 30+ CVEs to my name, found as a vulnerability researcher at Pluto Security.

https://avishaigonen123.github.io

https://www.linkedin.com/in/avishai-gonen-997148289

AGENDA

- Open redirect, in 60 seconds
- JBL: finding → fix → bypass DEMO
- Haaretz: from open redirect to phishing DEMO
- Haaretz, round 2: the newly found one DEMO
- Haaretz, round 3: a bypass of their fix LIVE DEMO

OPEN REDIRECT

A redirect you control

A site takes its destination from user input and sends you there - without checking where.



WHY IT MATTERS

Everyone underrates it

- Triage calls it low severity
- But it sends phishing from a domain users trust
- For hunters: a fast, common, low-hanging find

OWASP Top 10 2013 · A10 · CWE-601

CASE 01

JBL



Open redirect — JBL — Haaretz

DEMO

The report - YesWeHack

Bypass techniques

The @ trick

`trusted.com@evil.com`

Protocol-relative

`//evil.com`

Fragment

`trusted.com#@evil.com`

Subdomain

`trusted.com.evil.com`

Backslash

`https:/\evil.com`

Encoded slash

`trusted.com%2f@evil.com`

DEMO

Breaking the fix

```
https://www.jbl.com@evil.com
```

Filter sees jbl.com. Browser goes to evil.com.

CASE 01 · RECAP

JBL, in short

- An open redirect in a recipe-link email
- Reported, fixed, then bypassed with the @ trick
- $350 · CWE-601 · rated medium
- Lesson: sell the impact, verify the fix

CASE 02





Haaretz TheMarker

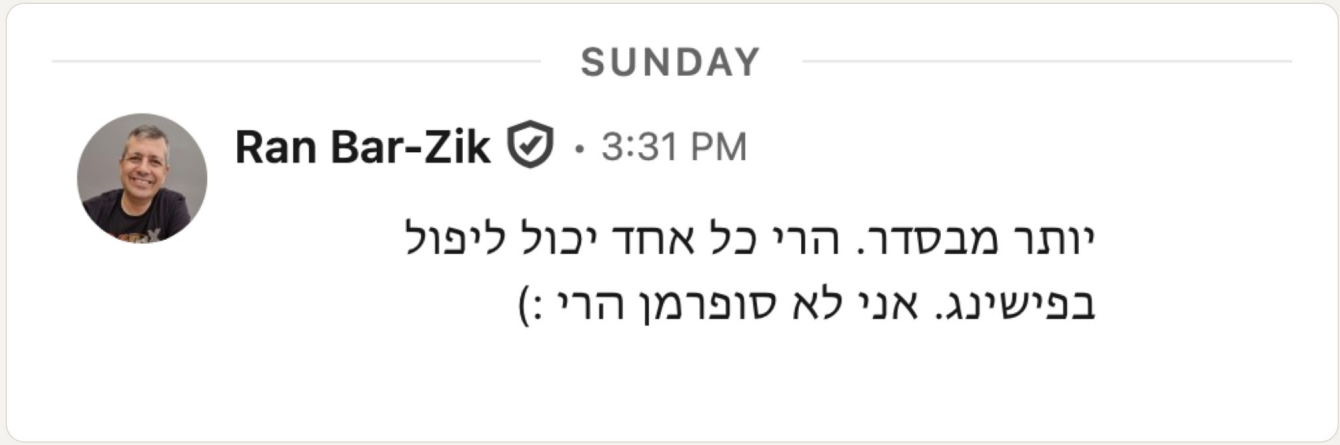
A phishing email that really came Haaretz.

Open redirect — JBL — Haaretz

DEMO

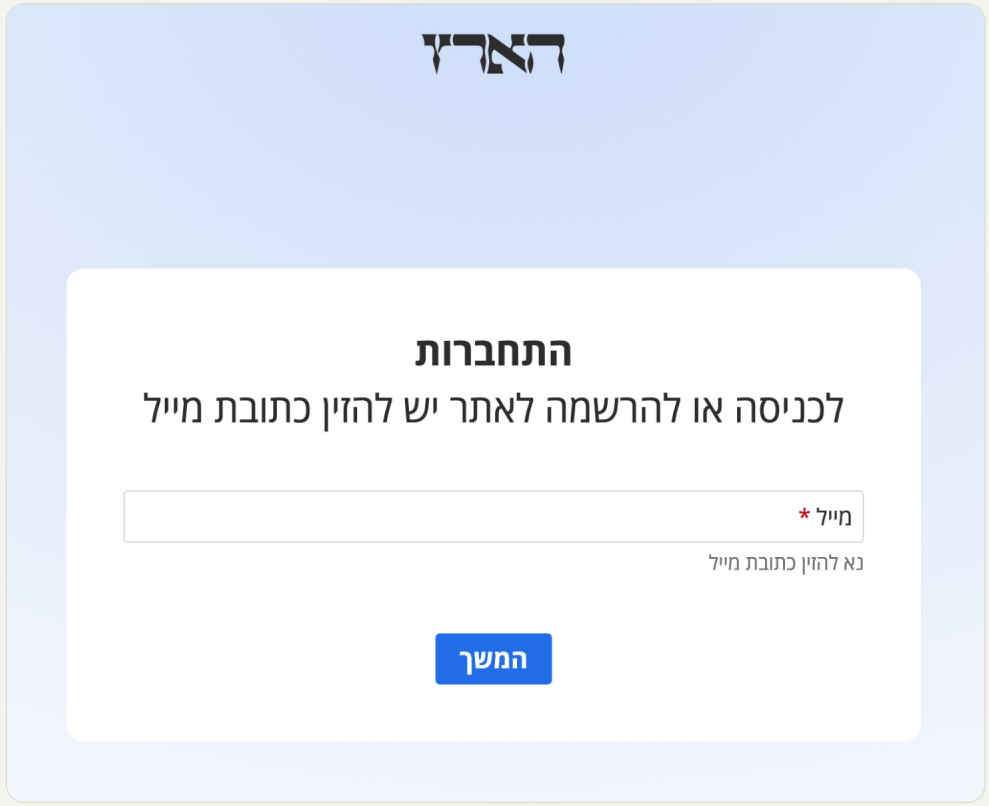
Watch this.

How I phished Ran Bar Zik.



Open redirect — JBL — Haaretz

Sign in - and it emails you

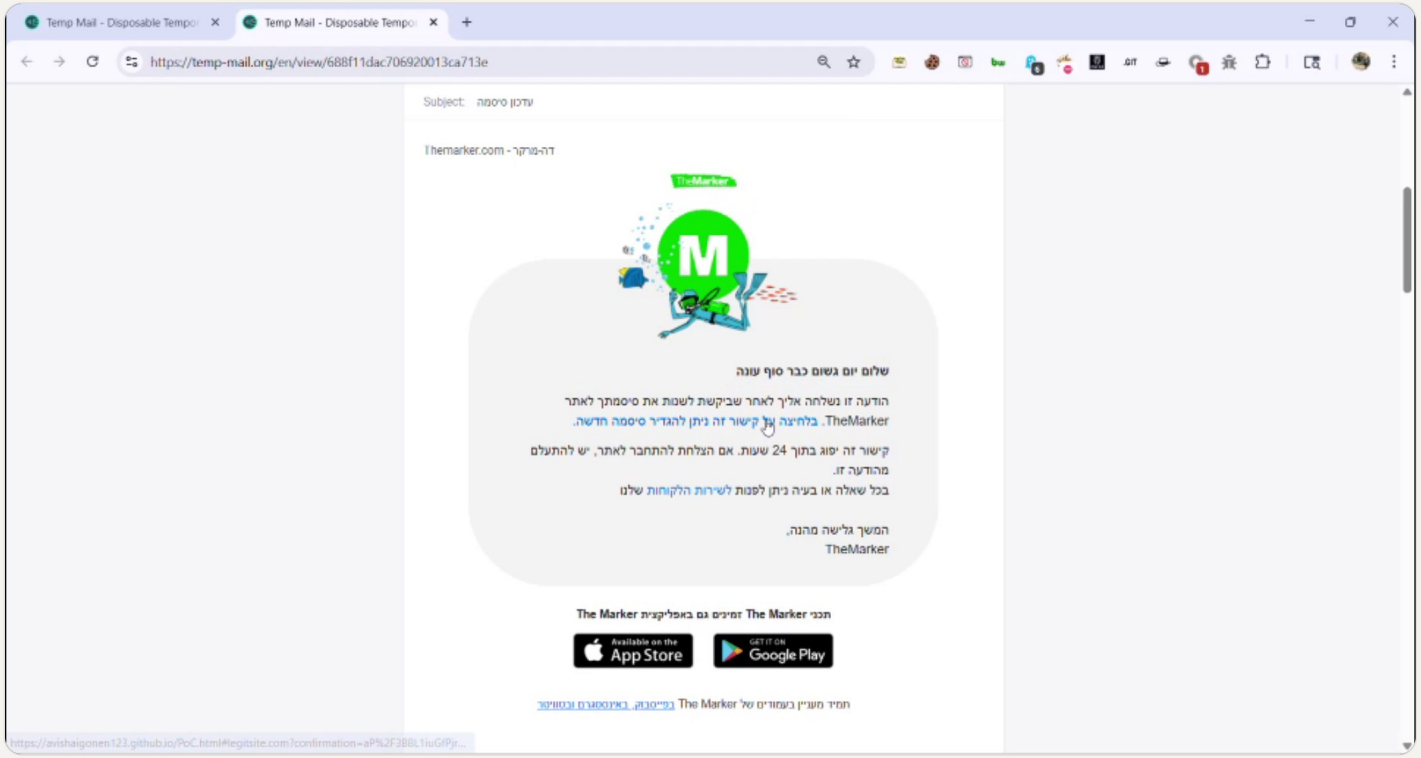


The mail is really from Haaretz. The link inside is mine.

Open redirect — JBL — Haaretz

DEMO

The redirect, start to finish



Open redirect — JBL — Haaretz

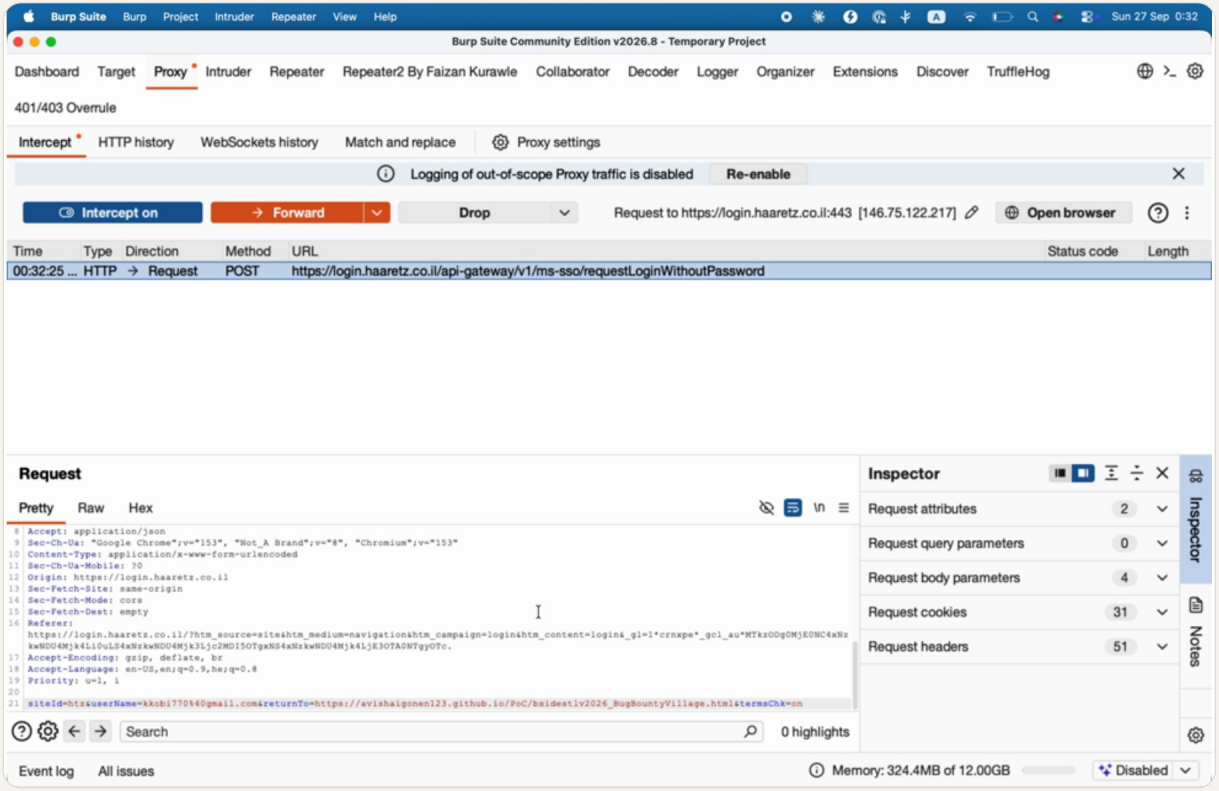
HAARETZ · V2

A year later, I found another.

Open redirect — JBL — Haaretz

DEMO

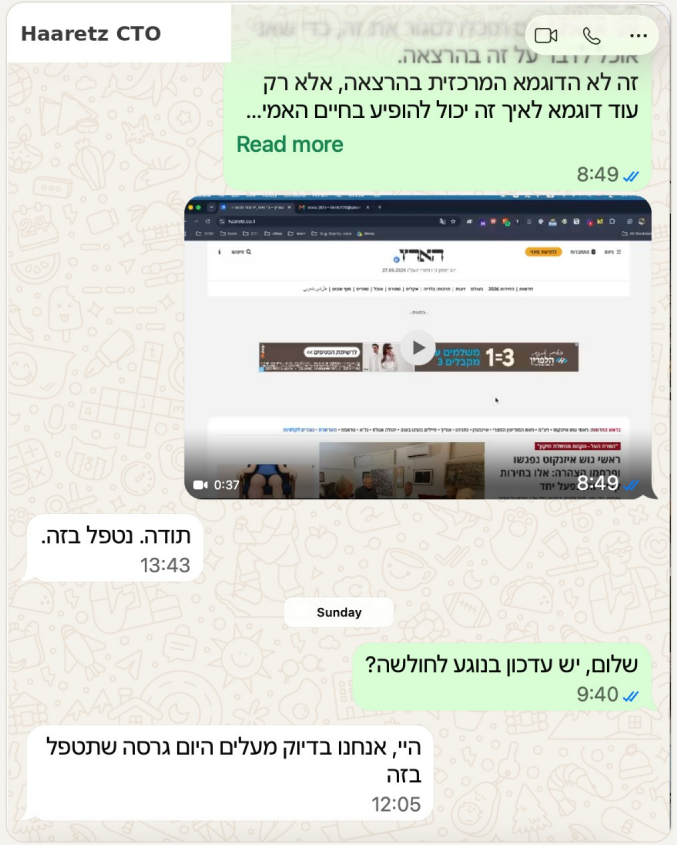
The returnTo redirect



`returnTo = my page`

login email → confirmation → my page

I reported it. They fixed it.

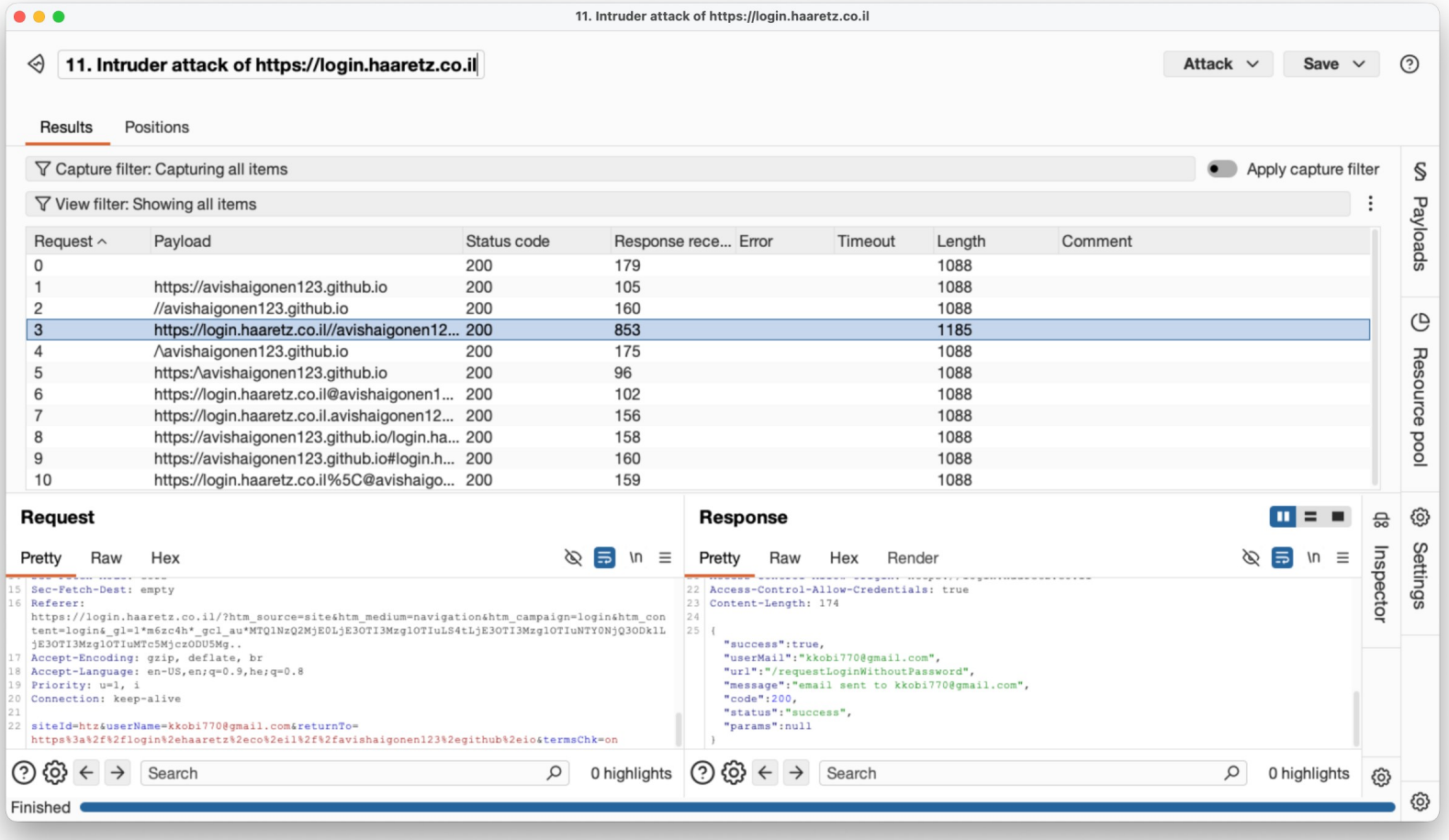


The CTO confirmed the fix - in the thread.

Reported, acknowledged, shipped.

Open redirect — JBL — Haaretz

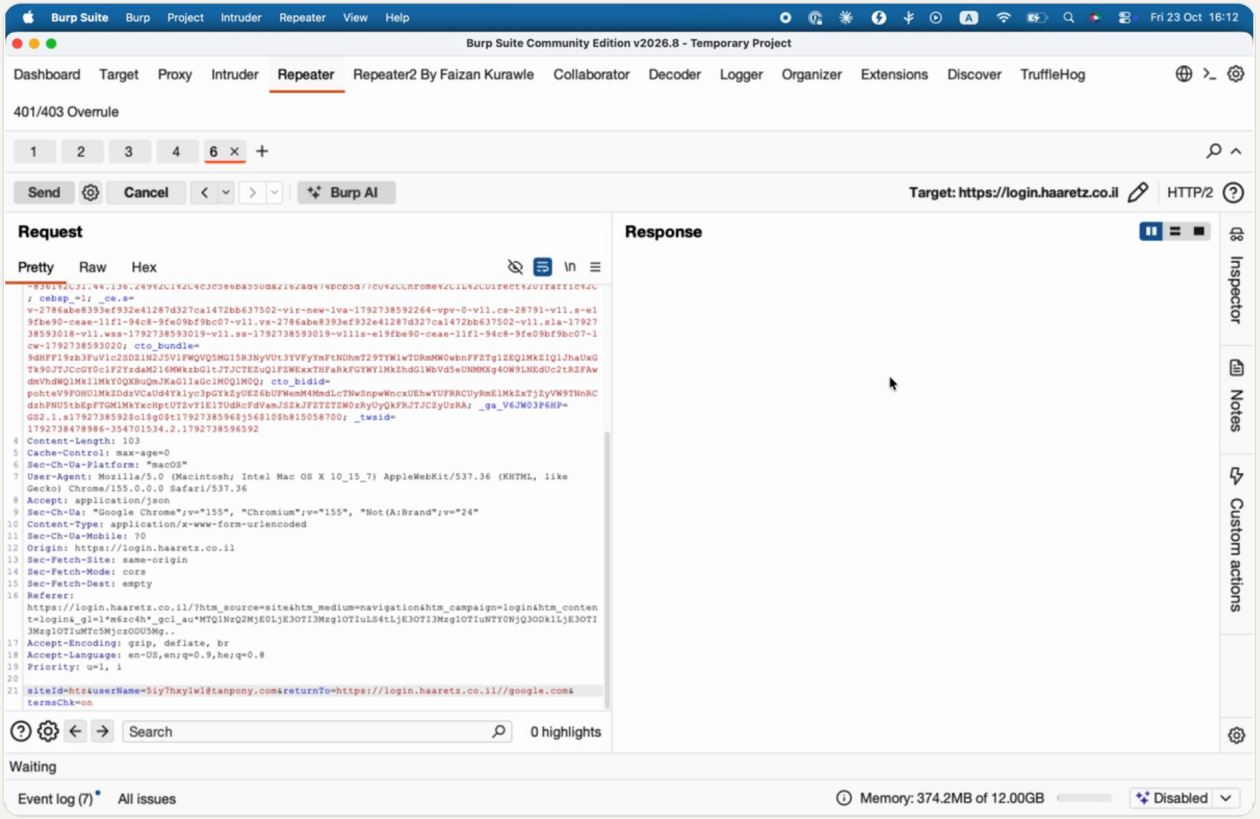
https://login.haaretz.co.il//avishaigonen123.github.io



Open redirect — JBL — Haaretz

DEMO · V3

Then one payload passed



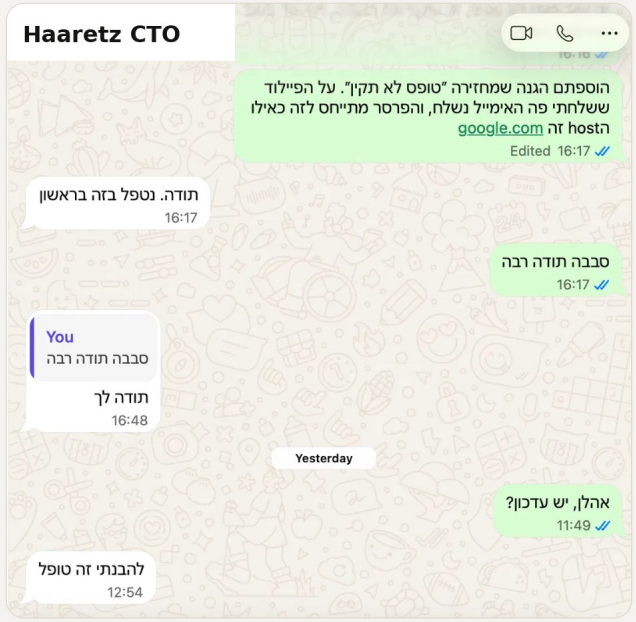
`login.haaretz.co.il//google.com`

Host check passes. The redirect uses the **path** - and // is protocol-relative.

Found while proving v2 was dead.
Reported again.

Open redirect — JBL — Haaretz

LIVE DEMO · HANDS ON



Today? Blocked.

Reported again - even the // bypass now returns **400**.

The CTO confirmed the v3 fix shipped - in the thread.

Open redirect — JBL — Haaretz

WHAT WE SAW

- **JBL** - an open redirect that sends phishing from jbl.com ($350, CWE-601).
- **JBL** - they “fixed” it; the @ trick walked right through.
- **Haaretz** - an open redirect that sends phishing from haaretz.com.
- **Haaretz, round 2** - another open redirect in the login, reported and fixed.
- **Haaretz, round 3** - their fix fell to a double-slash, found live and reported again.

Questions?



Slides & demos



Website



LinkedIn

Thank you.